

# Daily Vulnerability Report - 2026-09-09

Window (UTC): 2026-09-09T00:00 to 2026-09-10T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 09:51:28 UTC

| Total | New | Updated | KEV | Critical | High | Medium | Unscored | Watchlist | Packages |
|-------|-----|---------|-----|----------|------|--------|----------|-----------|----------|
| 1367  | 720 | 647     | 16  | 150      | 491  | 555    | 115      | 39        | 39       |

## P1 - Act now (KEV / high EPSS)

| ID                                                            | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package                                                                               | Description                                                                                                                                                                                                                                                                                                                                                                                |
|---------------------------------------------------------------|------|------|-----|-------|----------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-75650</a><br><small>Newly scored</small> | 10.0 | CRIT | Yes | 0.021 | adobe:commerce,<br>adobe:commerce_b2b,<br>adobe:magento                                                  | Adobe Commerce is affected by an Improper Neutralization of Special Elements Used in a Template Engine vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.                             |
| <a href="#">CVE-2026-86218</a><br><small>Newly scored</small> | 9.8  | CRIT | Yes | 0.007 | n-able:n-central                                                                                         | N-central is vulnerable to a pre-auth remote code execution This issue affects N-central: before 2026.3.1.14.                                                                                                                                                                                                                                                                              |
| <a href="#">CVE-2026-58704</a><br><small>Added to KEV</small> | 8.8  | HIGH | Yes | 0.001 | google:pixel                                                                                             | Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.                                                                                                                                                                                                       |
| <a href="#">CVE-2026-87491</a><br><small>New</small>          | 8.8  | HIGH | Yes | 0.01  | google:chrome                                                                                            | Out of bounds write in V8 in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                                                                                                                                                                                     |
| <a href="#">CVE-2025-25249</a><br><small>Added to KEV</small> |      |      | Yes | 0.024 | fortinet:multiple products                                                                               | Fortinet FortiOS, FortiSwitchManager, and FortiSASE contain a heap-based buffer overflow vulnerability that allows an attacker to execute unauthorized code or commands via specially crafted packets.                                                                                                                                                                                     |
| <a href="#">CVE-2026-19490</a><br><small>Added to KEV</small> |      |      | Yes | 0.056 | citrix:netscaler                                                                                         | Citrix NetScaler ADC and NetScaler Gateway contain an authentication-bypass vulnerability involving an alternate path or channel. When the NetScaler appliance is configured as an AAA virtual server or as a Gateway (SSL VPN, ICA Proxy, CVPN, or RDP Proxy), an unauthenticated remote threat actor may be able to bypass authentication.                                               |
| <a href="#">CVE-2026-20079</a><br><small>Added to KEV</small> |      |      | Yes | 0.758 | cisco:secure firewall management<br>center (fmc) and security cloud<br>control (scc) firewall management | Cisco Secure Firewall Management Center (FMC) Software and Cisco Security Cloud Control (SCC) Firewall Management contain an authentication Bypass using an alternate path or channel vulnerability that could allow an unauthenticated, remote attacker to bypass authentication and execute script files on an affected device to obtain root access to the underlying operating system. |
| <a href="#">CVE-2026-42016</a><br><small>Added to KEV</small> |      |      | Yes | 0.009 | jfrog:artifactory                                                                                        | JFrog Artifactory contains an incorrect authorization vulnerability that leads to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.                                                                                                                                                                                         |
| <a href="#">CVE-2026-42018</a><br><small>Added to KEV</small> |      |      | Yes | 0.009 | jfrog:artifactory                                                                                        | JFrog Artifactory contains an improper authentication vulnerability that could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.                                                                                                                                                           |
| <a href="#">CVE-2026-67277</a><br><small>Added to KEV</small> |      |      | Yes | 0.009 | mikrotik:routeros                                                                                        | MikroTik RouterOS contains a missing authentication for critical function vulnerability which allows kernel memory disclosure and denial of service in the btest service.                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-76460</a><br><small>Added to KEV</small> |      |      | Yes |       | cisco:identity services engine                                                                           | Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.                                                                                 |

| ID                                             | CVSS | Sev | KEV | EPSS  | Vendor / Product / Package                      | Description                                                                                                                                                                                                                                                   |
|------------------------------------------------|------|-----|-----|-------|-------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-76461</a><br>Added to KEV |      |     | Yes | 0.02  | cisco:secure email gateway                      | Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.                |
| <a href="#">CVE-2026-84869</a><br>Added to KEV |      |     | Yes | 0.007 | connectwise:screenconnect                       | ConnectWise ScreenConnect contains both an improper privilege management and missing authorization vulnerability that may allow an attacker to transfer and execute files through an active remote session without authorization or host confirmation.        |
| <a href="#">CVE-2026-85706</a><br>Added to KEV |      |     | Yes | 0.12  | gitlab:community edition and enterprise edition | GitLab Community Edition and Enterprise Edition contains a path traversal vulnerability that allows an unauthenticated user to read arbitrary files due to an improper path confinement and missing authentication enforcement in the repository commits API. |
| <a href="#">CVE-2026-86060</a><br>Added to KEV |      |     | Yes | 0.011 | mikrotik:routeros                               | MikroTik RouterOS contains an improper neutralization of argument delimiters in a command vulnerability which allows an attacker to change the trusted RouterOS policy mask, leading to privilege escalation.                                                 |
| <a href="#">CVE-2026-87886</a><br>Added to KEV |      |     | Yes |       | acronis:backup                                  | Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.                                                                                             |

## P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                           |
|------------------------------------------------|------|------|-----|-------|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-54745</a><br>Newly scored | 10.0 | CRIT |     | 0.004 |                            | Kubeflow Pipelines enables users to build and deploy portable, scalable machine learning workflows. Prior to 2.17.0, the Kubeflow Pipelines frontend exposes an unauthenticated server-side request forgery vulnerability through the /_proxy/ route in frontend/server/proxy-middlewares.ts. The _routePathWithReferer() function accepts an arbitrary attacker-controlled HTTP or HTTPS target and passes its origin to createPr... |
| <a href="#">CVE-2026-65956</a><br>Newly scored | 10.0 | CRIT |     | 0.004 |                            | KubePi is a Kubernetes multi-cluster management panel. In versions up to and including 1.6.15, the SSO configuration API endpoints are exposed on the same public routing boundary as the SSO login and callback endpoints, so SSO, OIDC, and SAML management operations can be reached without administrator authorization. Because reading, creating, and updating the global SSO configuration is not restricted to administra...  |
| <a href="#">CVE-2026-79696</a><br>New          | 10.0 | CRIT |     | 0.004 |                            | A Code Injection vulnerability in adk web in Google Cloud Agent Development Kit (ADK) for Python versions 2.0.0 through 2.6.0 on Python (OSS), Cloud Run, and GKE environments where pytest is installed allows an unauthenticated remote attacker to execute arbitrary code using a crafted test session replay.                                                                                                                     |
| <a href="#">CVE-2026-85061</a><br>Newly scored | 10.0 | CRIT |     | 0.003 |                            | MapLibre GL JS is an interactive vector tile map library for web browsers. Prior to 6.4.1, DOM.sanitize() in src/util/dom.ts iterates elem.attributes as a live NamedNodeMap while removeAttributes() removes attributes from the same collection, shifting indexes and skipping an adjacent dangerous attribute. An attacker who controls untrusted third-party style attribution strings or user-supplied custom attributions c...  |
| <a href="#">CVE-2026-85978</a><br>New          | 10.0 | CRIT |     | 0.009 |                            | An unauthenticated remote code execution vulnerability exists in the Policy Manager console of Akana API Platform. A path normalization discrepancy between the authentication filter and the servlet dispatcher allows a crafted request to bypass authentication and reach an endpoint that evaluates attacker-supplied script code without sandboxing, resulting in arbitrary code execution. Exploitation requires no authent...  |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-87827</a><br>New          | 10.0 | CRIT |     | 0.011 |                            | Certain KGUARD DVR devices running vulnerable firmware expose a system command execution service on all network interfaces without requiring authentication. A remote unauthenticated attacker with network access to the affected service can execute arbitrary system commands on the device, potentially resulting in complete compromise of the DVR. The vulnerability is known to have been exploited in the wild by the Mi...  |
| <a href="#">CVE-2026-55634</a><br>Newly scored | 9.9  | CRIT |     | 0.004 |                            | Pimcore is an Open Source Data & Experience Management Platform. Prior to 11.5.19, 12.3.10, and 2026.1.6, the class-definition import endpoint /pimcore-studio/api/class/definition/configuration-view/detail/{id}/import accepts a DataObject field name that is emitted without an identifier allowlist by lib/DataObject/ClassBuilder/FieldDefinitionPropertiesBuilder.php into generated PHP properties and by models/DataObj... |
| <a href="#">CVE-2026-62283</a><br>Newly scored | 9.9  | CRIT |     | 0.004 |                            | Nezha Monitoring is a self-hostable, lightweight, servers and websites monitoring and O&M tool. Nezha versions 1.14.13 through 1.14.14 and 2.0.0 through 2.0.9 do not bind stream identifiers created by CreateStream in service/rpc/io_stream.go to their creating user, and `GET /ws/terminal/:id` and `GET /ws/file/:id` only check whether the supplied UUID exists. An authenticated RoleMember who obtains a live stream UU... |
| <a href="#">CVE-2026-67401</a><br>New          | 9.9  | CRIT |     | 0.01  |                            | A vulnerability in cPanel allows a mail-enabled account to achieve remote code execution as root through SQLi in EmailTrack component                                                                                                                                                                                                                                                                                                |
| <a href="#">CVE-2025-67066</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                            | SQL Injection vulnerability in oasys sysoa version 1.0 allows a remote attacker to execute arbitrary code via the outtype parameter in the /outaddresspaging path                                                                                                                                                                                                                                                                    |
| <a href="#">CVE-2025-70290</a><br>Newly scored | 9.8  | CRIT |     | 0.005 |                            | An issue was discovered in Denx U-Boot before 2026.04. An integer overflow vulnerability in the ZFS filesystem support can be triggered by malformed on-disk metadata. The issue may result in incorrect memory allocation followed by out-of-bounds memory access, potentially leading to a crash or arbitrary code execution during the boot process.                                                                              |
| <a href="#">CVE-2025-70293</a><br>Newly scored | 9.8  | CRIT |     | 0.005 |                            | An issue was discovered in Denx U-Boot before 2026.04. An integer overflow vulnerability exists in function ext4fs_get_bgdtable, the size calculation can lead to under allocation and this underallocated buffer will be used in memcpy() which could lead to arbitrary code execution, a denial of service, or other unspecified impacts.                                                                                          |
| <a href="#">CVE-2026-21095</a><br>New          | 9.8  | CRIT |     | 0.005 | samsung:android            | Heap-based buffer overflow in DNG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.                                                                                                                                                                                                                                                                               |
| <a href="#">CVE-2026-21096</a><br>New          | 9.8  | CRIT |     | 0.005 | samsung:android            | Heap-based buffer overflow in JPEG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.                                                                                                                                                                                                                                                                              |
| <a href="#">CVE-2026-36433</a><br>New          | 9.8  | CRIT |     | 0.005 |                            | An issue in Actions Semiconductor Co. Ltd Tool- Media Player Utilities v.4.46 allows a physically proximate attacker execute arbitrary code via the Production.dll and RdiskUpgrade.exe components                                                                                                                                                                                                                                   |
| <a href="#">CVE-2026-37006</a><br>Newly scored | 9.8  | CRIT |     | 0.006 |                            | A vulnerability in the WebSocket endpoint of gpt-researcher v0.14.7 and before allows an unauthenticated remote attacker to achieve code execution via malicious Model Context Protocol configurations.                                                                                                                                                                                                                              |
| <a href="#">CVE-2026-37751</a><br>Newly scored | 9.8  | CRIT |     | 0.016 |                            | An OS command injection vulnerability in the killSessionSync function (lib/agent-runtime.ts) of 23blocks-OS ai-maestro v0.24.17 allows attackers to execute arbitrary commands via a crafted input.                                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-41871</a><br>New          | 9.8  | CRIT |     | 0.008 | apache:nutch               | Missing Authorization, Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.10 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Server. If an upgrade is not possible, user must restrict access to instances running the Nutch Service to trusted use...        |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-45018</a><br>Newly scored | 9.8  | CRIT |     | 0.007 |                            | Chainlit is a Python framework for building production-ready conversational AI applications. From 2.4.0rc0 until 2.12.0, Chainlit deployments with features.mcp.enabled set to true in .chainlit/config.toml expose the POST /mcp endpoint without requiring authentication. For stdio transport, the endpoint accepts a user-controlled fullCommand string. The validate_mcp_command() function in backend/chainlit/mcp.py check... |
| <a href="#">CVE-2026-50894</a><br>Newly scored | 9.8  | CRIT |     | 0.005 |                            | easyadmin v2.0.2.2 is vulnerable to Unrestricted Upload of File with Dangerous Type in the background management interface which allows authenticated remote attackers to execute arbitrary code and gain server privileges via a crafted file upload.                                                                                                                                                                               |
| <a href="#">CVE-2026-52103</a><br>Newly scored | 9.8  | CRIT |     | 0.006 |                            | A zero-click remote code execution (RCE) vulnerability in the /Terminal/Notification.hs component of SimpleX Chat before v6.5 allows attackers to execute arbitrary commands in the context of the application without user interaction via sending a crafted payload in a text message.                                                                                                                                             |
| <a href="#">CVE-2026-52490</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                            | An issue in libtiff 85f2ac8e0b01cb7db2bbebf4a3b891bdbef67938 allows an attacker to execute arbitrary code via the process_command_opts() function in tools/tiffcrop.c                                                                                                                                                                                                                                                                |
| <a href="#">CVE-2026-53611</a><br>Newly scored | 9.8  | CRIT |     | 0.01  |                            | Looking Glass is a modern, stateless network-diagnostic platform — a single self-contained Go binary that fronts a fleet of routers over SSH and exposes ping / traceroute / BGP lookups through a gRPC (ConnectRPC) API, an embedded SvelteKit web UI, and a lg-cli client. Prior to version 1.3.5, there is an OS Command Injection vulnerability resulting from an unanchored regular expression in the input validation layer... |
| <a href="#">CVE-2026-54569</a><br>Newly scored | 9.8  | CRIT |     | 0.008 |                            | SENAITE.CORE is the core framework for the SENAITE laboratory information management system. From 2.0.0 to 2.6.0, the SENAITE.CORE JSON API permits unauthenticated remote code execution through a two-request chain involving missing authorization and unsafe evaluation. The state-changing routes in src/bika/lims/jsonapi/update.py, including update, update_many, remove, doActionFor, doActionFor_many, and getusers, do... |
| <a href="#">CVE-2026-55546</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                            | QWED-MCP is a deterministic verification gateway for MCP. Prior to 0.2.1, verify_math_expression() in src/qwed_mcp/engines/math_engine.py passes attacker-controlled expression and claimed_result strings directly to SymPy's parse_expr() after only normalizing caret syntax to Python exponent syntax, without restricting global_dict, removing Python built-ins, or validating the expression AST. Because parse_expr() cal... |
| <a href="#">CVE-2026-56207</a><br>New          | 9.8  | CRIT |     | 0.005 | apache:impala              | Signature of Bearer token is not verified in last step of SAML2 authentication for Impala's hs2-http interface, allowing altering user name and acting as another user. This issue affects Apache Impala: >=4.0.0. Users are recommended to upgrade to version 4.5.2, which fixes this issue.                                                                                                                                        |
| <a href="#">CVE-2026-71624</a><br>Newly scored | 9.8  | CRIT |     | 0.005 |                            | An issue in esoTalk v.1.0.0g4 allows a remote attacker to execute arbitrary code via the core/models/ETMemberModel.class.php, core/controllers/ETMemberController.class.php, and core/lib/ET.class.php components                                                                                                                                                                                                                    |
| <a href="#">CVE-2026-71625</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                            | An issue in slimkit plus ThinkSNS+ v.2.4 allows a remote attacker to escalate privileges via the ResetPasswordController.php component                                                                                                                                                                                                                                                                                               |
| <a href="#">CVE-2026-71801</a><br>New          | 9.8  | CRIT |     | 0.005 |                            | An issue was discovered in s-pms SPMS-Server through v1.0. The application contains a hardcoded default access token secret within its core configuration file, which is not overridden or removed in the production environment profile. A remote, unauthenticated attacker can locally forge valid administrative session tokens to completely bypass the authentication mechanism gaining full unauthorized access to protecte... |
| <a href="#">CVE-2026-71805</a><br>New          | 9.8  | CRIT |     | 0.004 |                            | An arbitrary file upload and path traversal vulnerability exists in LZ-litchi 1.0.0. Unauthenticated remote attackers can upload arbitrary files and write them outside the intended storage directory via the directory parameter in POST /app-api/infra/file/upload.                                                                                                                                                               |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package  | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-75325</a><br>Newly scored | 9.8  | CRIT |     | 0.003 |                             | DWSurvey v6.14.0 is is vulnerable to authentication bypass via the '/api/dwsurvey/none/' and '/api/dwsurvey/up/**' parameters.                                                                                                                                                                                                                                                                                                       |
| <a href="#">CVE-2026-75337</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                             | The static resource interface /api/static/{deployKey}/ of Yu AI Code Mother v4.3 is vulnerable to path traversal. The user-controlled path is concatenated to the preview root directory without any normalization, allowing anonymous attackers to read files outside the preview root.                                                                                                                                             |
| <a href="#">CVE-2026-75338</a><br>Newly scored | 9.8  | CRIT |     | 0.003 |                             | disconf (Distributed Configuration Management Platform) 2.6.36 is vulnerable to Incorrect Access Control. The config-fetching APIs /api/config/item, /api/config/file, /api/config/list and /api/config/simple/list are exposed without authentication. The LoginInterceptor explicitly whitelists these four paths, so any anonymous attacker can read every configuration item and configuration file managed by the config cen... |
| <a href="#">CVE-2026-76904</a><br>Newly scored | 9.8  | CRIT |     | 0.018 |                             | GeoTools is an open source Java library that provides tools for geospatial data. Starting in version 30.5 and prior to versions 33.6, 34.5, and 33.6, an SQL Injection Vulnerability is present when executing OGC Filters with PostGIS DataStore implementation: `jsonArrayContains` function; Requires PostGIS 12 or greater with a String or JSON field. For PostGIS 12 and greater `jsonArrayContains(<column>, <pointer>, <v... |
| <a href="#">CVE-2026-77649</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                             | The internment crate 0.8.7 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.                                                                                                                                                                                      |
| <a href="#">CVE-2026-77650</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                             | The append-only-vec crate 0.1.9 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.                                                                                                                                                                                 |
| <a href="#">CVE-2026-77651</a><br>Newly scored | 9.8  | CRIT |     | 0.005 |                             | The arrayref crate 0.3.10 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.                                                                                                                                                                                       |
| <a href="#">CVE-2026-7861</a><br>Newly scored  | 9.8  | CRIT |     | 0.003 |                             | Deserialization of untrusted data vulnerability in Next4Biz Information Technologies Inc. CSM (Customer Service Management) allows Code Injection. This issue affects CSM (Customer Service Management): before 8.0.3.                                                                                                                                                                                                               |
| <a href="#">CVE-2026-78745</a><br>Newly scored | 9.8  | CRIT |     | 0.007 |                             | An issue in HiDPT/ Weyon HiDPTAndroid Hi3751V350 Hi3751V352E_DMO allows a remote attacker to execute arbitrary code via the Android Debug Bridge (ADB) daemon (adbd)                                                                                                                                                                                                                                                                 |
| <a href="#">CVE-2026-79391</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                             | No authentication exists in the MQTT service of Trueview 6.0.23.4. The MQTT broker accepts client connections on TCP port 1883 without requiring authentication, allowing a remote attacker with network access to establish an MQTT session and perform unauthorized publish or subscribe operations.                                                                                                                               |
| <a href="#">CVE-2026-79689</a><br>New          | 9.8  | CRIT |     | 0.019 | dell:secure_connect_gateway | Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.                                                                       |
| <a href="#">CVE-2026-79941</a><br>New          | 9.8  | CRIT |     | 0.019 | dell:secure_connect_gateway | Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.                                                                              |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package    | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|-------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-80129</a><br>Newly scored | 9.8  | CRIT |     | 0.004 | dell:secure_connect_gateway   | Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.                                                                                   |
| <a href="#">CVE-2026-80131</a><br>Newly scored | 9.8  | CRIT |     | 0.005 | dell:secure_connect_gateway   | Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.                                                                                   |
| <a href="#">CVE-2026-80172</a><br>New          | 9.8  | CRIT |     | 0.003 | dell:secure_connect_gateway   | Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Insufficient Verification of Data Authenticity vulnerability. An unauthenticated attacker with remote access could exploit this, leading to unauthorized access. This vulnerability is considered critical as an unauthenticated attacker can repeatedly reuse a captured request to generate ADMIN ac... |
| <a href="#">CVE-2026-84372</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                               | Predis is a flexible and feature-complete Redis and Valkey client for PHP. From version 3.0.0-RC1 until version 3.3.0, pipeline handling on aggregate cluster and replication connections reparses an already serialized RESP buffer in AbstractAggregateConnection::write() by splitting it with explode("\r\n") instead of honoring RESP length prefixes. Attacker-controlled keys or values containing CRLF sequences can ther... |
| <a href="#">CVE-2026-85102</a><br>New          | 9.8  | CRIT |     | 0.003 |                               | Improper certificate trust validation during VPN negotiation in Check Point Quantum Security Gateway may allow an unauthenticated remote attacker to execute arbitrary code on the Gateway.                                                                                                                                                                                                                                          |
| <a href="#">CVE-2026-85103</a><br>New          | 9.8  | CRIT |     | 0.004 |                               | A heap-based buffer overflow in VPN certificate ASN.1 decoding may allow an unauthenticated remote attacker to execute arbitrary code on Check Point Quantum Security Management and Quantum Security Gateway systems.                                                                                                                                                                                                               |
| <a href="#">CVE-2026-85506</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                               | ipmi-oem in FreeIPMI before 1.6.19 has a stack-based buffer overflow in _get_dell_system_info_idrac_info in ipmi-oem/ipmi-oem-dell.c (idrac-info subcommand to dell get-system-info).                                                                                                                                                                                                                                                |
| <a href="#">CVE-2026-86478</a><br>Newly scored | 9.8  | CRIT |     | 0.004 |                               | In JetBrains YouTrack before 2025.3.161254, 2026.1.14042 improper authentication in YouTrack Helpdesk allowed unauthenticated account takeover via a self-asserted email address                                                                                                                                                                                                                                                     |
| <a href="#">CVE-2026-86480</a><br>Newly scored | 9.8  | CRIT |     | 0.003 |                               | In JetBrains Hub before 2026.2.52442 an unauthenticated attacker could register a trusted service and gain superuser privileges                                                                                                                                                                                                                                                                                                      |
| <a href="#">CVE-2026-87534</a><br>New          | 9.8  | CRIT |     | 0.002 | google:android, google:chrome | Missing authorization in WebView in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)                                                                                                                                                                                |
| <a href="#">CVE-2026-87544</a><br>New          | 9.8  | CRIT |     | 0.003 | google:chrome                 | Incorrect authorization in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to bypass system access restrictions into a privileged page via a crafted HTML page. (Chromium security severity: Low)                                                                                                                                                                                                       |
| <a href="#">CVE-2026-87595</a><br>New          | 9.8  | CRIT |     | 0.003 | google:chrome                 | Server-side request forgery in Mobile in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Low)                                                                                                                                                                                                |
| <a href="#">CVE-2026-53649</a><br>Newly scored | 9.6  | CRIT |     | 0.002 |                               | Joro is a web exploitation framework. Prior to version 1.1.1, Joro's default proxy mode exposes a local API on 127.0.0.1:9090 that performs no authentication and applies a wildcard CORS policy. Because plugin uploads use the CORS-safelisted multipart/form-data content type, cross-origin JavaScript on any page the operator visits can reach privileged endpoints - including uploading a native plugin and triggering a ... |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package    | Description                                                                                                                                                                                                                                                                                                                                                                                                                           |
|------------------------------------------------|------|------|-----|-------|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-54523</a><br>Newly scored | 9.6  | CRIT |     | 0.004 |                               | Kyverno is a policy engine designed for cloud native platform engineering teams. From 1.18.0 until 1.18.2, the NamespacedMutatingPolicy CEL compiler exposes the generator library to matchConditions, allowing a namespace-scoped policy to invoke generator.apply(namespace, resources) with an arbitrary target namespace. The validation in pkg/cel/policies/mpol/validate.go checks that the policy compiles but does not en...  |
| <a href="#">CVE-2026-54694</a><br>New          | 9.6  | CRIT |     | 0.003 |                               | SkillTree is a micro-learning gamification platform. Prior to version 4.4.2, two independent code flaws combine into a single exploitable attack chain, with three distinct exploitation paths of escalating impact. `StringHighlighter.js` builds an HTML string by interpolating raw `value` substrings directly into a template literal with no HTML entity encoding. `HighlightedValue.vue` renders that string — and all unf...  |
| <a href="#">CVE-2026-54754</a><br>Newly scored | 9.6  | CRIT |     | 0.003 |                               | Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.19, marketplace settlement in core/kapp/market/market.go reads MarketOrderData.ReferralPercentage from the listing while reading asset.Royalties.MarketPercentage live at purchase time. An asset owner can create a valid listing and then use AssetTrigger.UpdateRoyalties to make the combined referral and royalty percentages exceed the ...  |
| <a href="#">CVE-2026-54755</a><br>Newly scored | 9.6  | CRIT |     | 0.004 |                               | Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.19, split-royalty fields decoded in core/kapp/builtInFunctions/utills.go can contain values greater than core.HundredPercent, and core/kapp/kda/create.go and core/kapp/kda/trigger.go sum those values in uint32 accumulators. Crafted values such as two 0x80000000 entries wrap the validation sum to zero and pass CheckValid100Params. Roy... |
| <a href="#">CVE-2026-86751</a><br>New          | 9.6  | CRIT |     | 0.003 | snipeitapp:snipe-it           | Snipe-IT before 8.7.0 fails to properly sanitize markdown image syntax in note fields, allowing authenticated users to read arbitrary server files and issue server-side HTTP requests. Attackers can submit markdown image syntax in checkout acceptance notes that survive HTML escaping, are expanded by CommonMark parser, and resolved by laravel-mail-auto-embed via file_get_contents or curl, exfiltrating sensitive file...  |
| <a href="#">CVE-2026-87438</a><br>New          | 9.6  | CRIT |     | 0.006 | google:android, google:chrome | Out of bounds write in WebGL in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)                                                                                                                                                                                                            |
| <a href="#">CVE-2026-87448</a><br>New          | 9.6  | CRIT |     | 0.005 | google:chrome                 | Use after free in DevTools in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)                                                                                                                                                                                                                                 |
| <a href="#">CVE-2026-87455</a><br>New          | 9.6  | CRIT |     | 0.004 | google:chrome                 | Use after free in Aura in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                                                                                                                                                                                                                      |
| <a href="#">CVE-2026-87464</a><br>New          | 9.6  | CRIT |     | 0.006 | google:chrome                 | Use after free in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)                                                                                                                                                                                                                               |
| <a href="#">CVE-2026-87470</a><br>New          | 9.6  | CRIT |     | 0.004 | apple:macos, google:chrome    | Improper quantity validation in Tint in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                                                                                                                                                                                              |
| <a href="#">CVE-2026-87474</a><br>New          | 9.6  | CRIT |     | 0.005 | google:chrome                 | Use after free in Payments in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                                                                                                                                                                                                    |
| <a href="#">CVE-2026-87488</a><br>New          | 9.6  | CRIT |     | 0.005 | google:android, google:chrome | Use after free in WebGL in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)                                                                                                                                                                                                                 |
| <a href="#">CVE-2026-87492</a><br>New          | 9.6  | CRIT |     | 0.003 | google:chrome                 | Incorrect authorization in DevTools in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                                                                                                                                                                                           |

| ID                                    | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package       | Description                                                                                                                                                                                                                                                          |
|---------------------------------------|------|------|-----|-------|----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-87494</a><br>New | 9.6  | CRIT |     | 0.003 | google:chrome, microsoft:windows | Use after free in Browser in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                  |
| <a href="#">CVE-2026-87500</a><br>New | 9.6  | CRIT |     | 0.003 | google:chrome                    | Improper validation of array index in ANGLE in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                  |
| <a href="#">CVE-2026-87504</a><br>New | 9.6  | CRIT |     | 0.004 | google:chrome                    | Use after free in Core in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted Chrome extension. (Chromium security severity: Medium)                            |
| <a href="#">CVE-2026-87512</a><br>New | 9.6  | CRIT |     | 0.005 | google:chrome, microsoft:windows | Use after free in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                                    |
| <a href="#">CVE-2026-87520</a><br>New | 9.6  | CRIT |     | 0.004 | google:android, google:chrome    | Use after free in Dawn in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                                     |
| <a href="#">CVE-2026-87526</a><br>New | 9.6  | CRIT |     | 0.004 | google:chrome                    | Use after free in Passwords in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via UI Interaction. (Chromium security severity: Medium)                       |
| <a href="#">CVE-2026-87527</a><br>New | 9.6  | CRIT |     | 0.005 | google:chrome                    | Buffer overflow in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)                                                             |
| <a href="#">CVE-2026-87528</a><br>New | 9.6  | CRIT |     | 0.003 | google:chrome, microsoft:windows | Type confusion in Rust in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                                       |
| <a href="#">CVE-2026-87529</a><br>New | 9.6  | CRIT |     | 0.005 | google:chrome                    | Numeric truncation error in Media in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                                          |
| <a href="#">CVE-2026-87547</a><br>New | 9.6  | CRIT |     | 0.004 | google:chrome                    | Incorrect reference resolution in FileSystem in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium) |
| <a href="#">CVE-2026-87558</a><br>New | 9.6  | CRIT |     | 0.004 | apple:macos, google:chrome       | Use after free in Payments in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                                     |
| <a href="#">CVE-2026-87581</a><br>New | 9.6  | CRIT |     | 0.004 | google:chrome                    | Use after free in Payments in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                     |
| <a href="#">CVE-2026-87607</a><br>New | 9.6  | CRIT |     | 0.004 | apple:macos, google:chrome       | Use after free in Device in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                           |
| <a href="#">CVE-2026-87609</a><br>New | 9.6  | CRIT |     | 0.004 | apple:iphone_os, google:chrome   | Use after free in Sharing in Google Chrome on on iOS prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)                                                |
| <a href="#">CVE-2026-87621</a><br>New | 9.6  | CRIT |     | 0.003 | google:chrome, microsoft:windows | Out of bounds write in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                   |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package       | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-87634</a><br>New          | 9.6  | CRIT |     | 0.004 | google:chrome                    | Use after free in WebPackaging in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)                                                                                                                                                                                                                |
| <a href="#">CVE-2026-87637</a><br>New          | 9.6  | CRIT |     | 0.003 | apple:macos, google:chrome       | Use after free in Extensions in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                                                                                                                                                                                                                 |
| <a href="#">CVE-2026-87638</a><br>New          | 9.6  | CRIT |     | 0.003 | google:chrome                    | Out of bounds write in Media in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                                                                                                                                                                                                               |
| <a href="#">CVE-2026-87643</a><br>New          | 9.6  | CRIT |     | 0.004 | google:android, google:chrome    | Integer overflow in GPU in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)                                                                                                                                                                                                      |
| <a href="#">CVE-2026-87646</a><br>New          | 9.6  | CRIT |     | 0.004 | google:chrome                    | Use after free in Web Authentication in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                                                                                                                                                                                                     |
| <a href="#">CVE-2026-87650</a><br>New          | 9.6  | CRIT |     | 0.003 | google:chrome                    | Out of bounds read in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                                                                                                                                                                                                  |
| <a href="#">CVE-2026-87654</a><br>New          | 9.6  | CRIT |     | 0.004 | google:chrome, microsoft:windows | Buffer overflow in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)                                                                                                                                                                                                                   |
| <a href="#">CVE-2026-39975</a><br>Newly scored | 9.4  | CRIT |     | 0.003 |                                  | Combodo iTop is a web-based IT service management tool. Prior to 3.2.3, unauthenticated users could delete the .readonly file on iTop instances, leading to code execution. This file, created during the setup process, prevents users from performing write actions. This issue has been fixed in version 3.2.3.                                                                                                                   |
| <a href="#">CVE-2026-16876</a><br>Newly scored | 9.3  | CRIT |     | 0.003 |                                  | An authentication bypass vulnerability exists in the WebGUI of Series UNIVERGE IX-R/IX-V. A user could bypass authentication and execute arbitrary CLI commands by tampering with WebGUI messages and sending them to the device via internet.                                                                                                                                                                                       |
| <a href="#">CVE-2026-47156</a><br>New          | 9.3  | CRIT |     | 0.005 |                                  | MantisBT is an open source bug tracker. Versions 2.28.3 and earlier contain a critical authentication bypass in the SOAP API's mci_check_login() function. Any user knowing any valid cookie_string can authenticate as any other user (knowing their username), including the administrator, without knowing the target's password. The vulnerability is exploitable with zero prior access on default MantisBT installations be... |
| <a href="#">CVE-2026-48996</a><br>Newly scored | 9.3  | CRIT |     | 0.002 |                                  | Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter does not sanitize note titles, and the GeoMap note view interpolates a marker note's title into raw HTML that is rendered as innerHTML, allowing an attacker-supplied import archive to inject script that runs when the map is displayed. Because Safe import neutralizes scripts b... |
| <a href="#">CVE-2026-51106</a><br>Newly scored | 9.3  | CRIT |     | 0.002 |                                  | An issue in TokTok qTox v1.18.4 allows a local attacker to cause a denial of service via the src/persistence/serialize.cpp component                                                                                                                                                                                                                                                                                                 |
| <a href="#">CVE-2026-53578</a><br>Newly scored | 9.3  | CRIT |     | 0.002 |                                  | Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter sanitizes HTML only for text notes and excludes the mindMap note type, whose JSON content is stored without sanitization, allowing an attacker-supplied import archive to embed a payload that renders as arbitrary HTML. A mind map node can carry a dangerouslySetInnerHTML proper... |
| <a href="#">CVE-2026-53579</a><br>Newly scored | 9.3  | CRIT |     | 0.002 |                                  | Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter sanitizes HTML only for text notes and excludes the book note type, whose content is stored without sanitization and later rendered as HTML, allowing an attacker-supplied import archive to embed a payload that executes as script. A book note's content is routed through the sa... |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                              |
|------------------------------------------------|------|------|-----|-------|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-53670</a><br>Newly scored | 9.3  | CRIT |     | 0.003 |                            | PREVAIL is a Polynomial-Runtime EBPF Verifier using an Abstract Interpretation Layer. Prior to version 0.2.4, in the Prevail eBPF verifier, EbpfTransformer::add() silently skips offset-variable updates when the destination register carries a non-singleton typeset (two or more simultaneously possible pointer types). Subsequent bounds checks use the stale offset and accept out-of-bounds memory accesses, so a crafted...     |
| <a href="#">CVE-2026-53671</a><br>Newly scored | 9.3  | CRIT |     | 0.003 |                            | PREVAIL is a Polynomial-Runtime EBPF Verifier using an Abstract Interpretation Layer. Prior to version 0.2.4, the abstract transformer in prevail treats writes through a T_CTX-typed base register as a silent no-op: do_mem_store in src/crab/ebpf_transformer.cpp only models T_STACK stores, and the checker's T_CTX bounds arm never tests AccessType::write. An attacker can craft an eBPF program that overwrites a contex...     |
| <a href="#">CVE-2026-55220</a><br>Newly scored | 9.3  | CRIT |     | 0.005 |                            | Pimcore is an Open Source Data & Experience Management Platform. Prior to 11.5.19, 12.3.10, and 2026.1.6, Pimcore\Model\DataObject\ClassDefinition\Data\Hotspotimage::getDataFromResource() in models\DataObject\ClassDefinition\Data\Hotspotimage.php passes the field __hotspots object-store column to Pimcore\Tool\Serialize::unserialize() without an allowed-classes restriction after JSON decoding fails. An attacker wit...     |
| <a href="#">CVE-2026-55378</a><br>Newly scored | 9.3  | CRIT |     | 0.006 |                            | JS Recon is a JavaScript enumeration and SAST tool. From 1.2.1-beta.1 until 1.3.1-beta.2, the PR Branch Checker workflow in .github/workflows/pr_checker.yml places github.head_ref and github.event.pull_request.head.repo.full_name into BRANCH_NAME and SOURCE_REPO and interpolates those untrusted values into a shell gh pr comment command. A remote user who opens a pull request can use shell metacharacters in a branc...     |
| <a href="#">CVE-2026-57910</a><br>Newly scored | 9.3  | CRIT |     | 0.002 |                            | Improper authentication in the WatchGuard Agent allows an unauthenticated attacker with network access to cause the agent to execute arbitrary code with elevated privileges.                                                                                                                                                                                                                                                            |
| <a href="#">CVE-2026-63310</a><br>Updated      | 9.3  | CRIT |     |       | pip:nlTK                   | ## Duplicate Advisory This advisory has been withdrawn because it is a duplicate of GHSA-5wp5-5229-5g6q. This link is maintained to preserve external references. ## Original Description NLTK before 3.9.3 fails to verify file integrity after downloading packages and before extraction in the downloader module. Attackers can perform man-in-the-middle attacks or DNS poisoning to inject malicious package contents tha...       |
| <a href="#">CVE-2026-65641</a><br>Newly scored | 9.3  | CRIT |     | 0.005 |                            | A vulnerability allowing an unauthenticated network attacker to coerce SMB authentication from the service account.                                                                                                                                                                                                                                                                                                                      |
| <a href="#">CVE-2026-68929</a><br>Newly scored | 9.3  | CRIT |     | 0.003 |                            | FastGPT is an open-source LLM platform for building AI applications on a knowledge base. In versions prior to 4.15.2, the WeChat (iLink) share-channel endpoints authorize requests using only the public shareId, with no authenticated identity or team-ownership check. As a result, an unauthenticated attacker who knows a victim team's shareId can take that team's WeChat bot offline or hijack the channel to their own ...     |
| <a href="#">CVE-2026-73251</a><br>Newly scored | 9.3  | CRIT |     | 0.002 |                            | Mongoose is an embedded web server and network library. Prior to 7.23, a network attacker can impersonate a TLS server to a Mongoose client configured with a multi-certificate CA bundle. In src/tls_builtin.c, the mg_tls_init() function stores the bundle in tls->ca_bundle_der while tls->ca_der.len remains zero, and mg_tls_recv_cert() uses tls_bundle_find() to accept a Common Name match without calling mg_tls_verify...     |
| <a href="#">CVE-2026-77413</a><br>Newly scored | 9.3  | CRIT |     | 0.005 |                            | JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.0, the src/functions.js lookup function lacked an Object.prototype.hasOwnProperty check and allowed crafted expressions to access inherited prototype members. An attacker able to supply an expression could use inherited prototype setters and getters, constructor access, valueOf, and process.getBuiltinModule to reach the child_process modul...     |
| <a href="#">CVE-2026-77414</a><br>Newly scored | 9.3  | CRIT |     | 0.004 |                            | JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.1, the src/jsonata.js environment.lookup function used a bypassable hasOwnProperty check. Crafted expressions could use \$hasOwnProperty, \$spread, \$string, prototype access, and \$constructor to reach the object prototype and invoke process.getBuiltinModule with child_process, executing arbitrary code with the privileges of the host process.... |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                            |
|------------------------------------------------|------|------|-----|-------|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-77415</a><br>Newly scored | 9.3  | CRIT |     | 0.006 |                            | JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.1, crafted JSONata expressions could chain several object-integrity weaknesses to execute arbitrary code. The chain could overwrite \$clone to mutate objects through evaluateTransformExpression, expose and deconstruct JSONata functions or lambdas through \$merge.*, replace proc.arguments.forEach used by applyProcedure, and forge internal lam... |
| <a href="#">CVE-2026-77644</a><br>Newly scored | 9.3  | CRIT |     | 0.003 |                            | A critical bypass access control vulnerability has been reported in PTC Windchill Risk and Reliability (WRR) Enterprise Edition.                                                                                                                                                                                                                                                                                                       |
| <a href="#">CVE-2026-77776</a><br>Newly scored | 9.3  | CRIT |     | 0.003 |                            | Headroom's LLM proxy derives the memory owner from the x-headroom-user-id request header. The header is read directly at several points in headroom/proxy/handlers/openai.py, including the chat completion and websocket paths, and nothing binds the value to the caller. A client can therefore name another user's identifier and read or write that user's stored LLM memory. The fix introduces a single resolve_memory_ide...   |
| <a href="#">CVE-2026-85391</a><br>Newly scored | 9.3  | CRIT |     | 0.003 |                            | Peppermint through 0.5.5 contains a hardcoded JWT signing secret in docker-compose.yml that allows unauthenticated attackers to forge session tokens for any account. Attackers can use the published secret to mint valid tokens for arbitrary user IDs and access protected endpoints without credentials.                                                                                                                           |
| <a href="#">CVE-2026-87929</a><br>New          | 9.3  | CRIT |     | 0.003 |                            | MaxSite CMS through 109.6 ships with a hardcoded session encryption key in application/config/config.php that is never changed during installation, allowing unauthenticated attackers to forge administrator session cookies. Attackers can mint a malicious ci_session cookie with administrator privileges by computing an HMAC-SHA1 using the publicly known encryption key, bypassing authentication checks in is_login() an...   |
| <a href="#">CVE-2026-88069</a><br>New          | 9.3  | CRIT |     | 0.003 |                            | Pandora contains a path traversal vulnerability in its archive extraction worker. When processing a specially crafted archive or disk image, attacker-controlled file paths could be used without ensuring that the resulting destination remained within the intended extraction directory. An attacker able to submit a malicious file for analysis could use path traversal sequences or crafted paths to cause extracted con...    |
| <a href="#">CVE-2026-63382</a><br>Newly scored | 9.2  | CRIT |     | 0.006 |                            | Libevent is an event notification library. Prior to 2.1.13 and 2.2.2-alpha, the libevent evhttp parser in http.c inconsistently handles duplicate Transfer-Encoding headers, comma-separated Transfer-Encoding values, and bare line feeds in chunked framing. evhttp_find_header can select only the first header, evhttp_check_transfer_encoding_ was absent so the previous whole-string comparison fails to recognize valid l...   |
| <a href="#">CVE-2026-63385</a><br>Newly scored | 9.2  | CRIT |     | 0.004 |                            | Libevent is an event notification library. Prior to 2.1.13 and 2.2.2-alpha, libevent has two HTTP parsing weaknesses in http.c. evhttp_decode_uri_internal decodes percent-encoded %00 bytes into literal NUL characters, which can cause downstream C string operations to truncate a path and bypass validation performed on a different representation. evhttp_header_is_valid_value also accepts obsolete line folding in hea...   |
| <a href="#">CVE-2026-67276</a><br>Newly scored | 9.2  | CRIT |     | 0.002 |                            | RouterOS does not compare the complete RSA public key when matching an SSH authentication request to an authorized user key, checking the key type and modulus but omitting the exponent. Because signature verification uses the client-supplied key, an attacker knowing an authorized RSA modulus can supply a key with exponent one, forge a valid signature, and open an SSH command channel as the target user without the ...   |
| <a href="#">CVE-2026-67402</a><br>Newly scored | 9.2  | CRIT |     | 0.003 |                            | An insecure Apache configuration in ConfigServer Security & Firewall maps /usr/bin as CGI programs through the Messenger v3 HTTPS virtual host. A remote unauthenticated attacker whose address is blocked can request a mapped executable and run arbitrary commands as the Apache user. The vulnerability affects installations where CSF Messenger v3 and its HTTPS mode are enabled. WebPros addressed the vulnerability in v...   |
| <a href="#">CVE-2026-77645</a><br>Newly scored | 9.2  | CRIT |     | 0.005 |                            | A critical remote code execution (RCE) vulnerability has been reported in PTC Windchill and PTC FlexPLM. The vulnerability may be exploited through the deserialization of untrusted data.                                                                                                                                                                                                                                             |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-82090</a><br>Newly scored | 9.2  | CRIT |     | 0.003 |                            | Pocket through 8.33.0.0 allows XSS because "Save to Pocket" injects external HTML into the DOM. JavaScript code can alter the application state via native bridge methods.                                                                                                                                                                                                                                                           |
| <a href="#">CVE-2026-87930</a><br>New          | 9.2  | CRIT |     | 0.003 |                            | MaxSite CMS through 109.6 passes the ci_session cookie to unserialize() without class restrictions, allowing unauthenticated attackers to inject PHP objects. Attackers can forge valid session cookies using the hardcoded encryption key to trigger magic methods and corrupt application state or achieve code execution if gadget classes exist.                                                                                 |
| <a href="#">CVE-2025-51679</a><br>Newly scored | 9.1  | CRIT |     | 0.004 |                            | An issue was discovered in openRISC OR1200 commit 83ac6b. A mismatch between the RTL and netlist can lead to unexpected behavior.                                                                                                                                                                                                                                                                                                    |
| <a href="#">CVE-2026-16272</a><br>New          | 9.1  | CRIT |     | 0.001 |                            | Use of less trusted source vulnerability in PayTR Payment and Electronic Money Institution Inc. PayTR Virtual Pos iFrame API (v9x) WHMCS Module allows Exploitation of Trusted Identifiers. This issue affects PayTR Virtual Pos iFrame API (v9x) WHMCS Module: from v9.0.0 before v9.0.3.                                                                                                                                           |
| <a href="#">CVE-2026-22590</a><br>New          | 9.1  | CRIT |     | 0.004 |                            | eprosima Fast DDS is a C++ implementation of the DDS (Data Distribution Service) standard of the OMG (Object Management Group). Versions prior to 2.6.12, 2.14.6, 3.2.4, 3.3.1, and 3.4.2 have a remotely triggerable Out-of-Bounds Read while processing RTPS `DATA_FRAG` submessages. An attacker can craft a `DATA_FRAG` with a large `sampleSize` but a small actual payload, and set `fragmentsInSubmessage` such that the r... |
| <a href="#">CVE-2026-41869</a><br>New          | 9.1  | CRIT |     | 0.008 | apache:nutch               | Missing Authorization, Improper Resource Shutdown and Job Interruption vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.10 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Server. If an upgrade is not possible, user must restrict access to instances running the Nutch Service to trusted users only. Please, also visit the Ap...         |
| <a href="#">CVE-2026-49849</a><br>Newly scored | 9.1  | CRIT |     | 0.009 |                            | xShop is an open-source shop developed in Laravel. An Unrestricted File Upload vulnerability in xShop version 3.0.3 allows an authenticated administrator to upload executable files (e.g., .php). By uploading a specially crafted php file, an attacker can achieve Remote Code Execution (RCE) on the server, leading to a full system compromise. Version 3.0.4 fixes the issue.                                                 |
| <a href="#">CVE-2026-52766</a><br>Newly scored | 9.1  | CRIT |     | 0.003 |                            | YesWiki is a wiki system written in PHP. Prior to version 4.6.6, the {{erasespamedcomments}} wiki action (actions/EraseSpamedCommentsAction.php) accepts a suppr[] array from POST and deletes every wiki page whose tag appears in that array, with no authorization check anywhere in the action body or in the page-deletion path it invokes. Combined with YesWiki's allow-by-default action ACL model, any user who has page... |
| <a href="#">CVE-2026-53939</a><br>New          | 9.1  | CRIT |     | 0.002 |                            | OpenIDC/cjose is a C library implementing the Javascript Object Signing and Encryption (JOSE). In versions 0.6.1 through 0.6.2.5, when cjose encrypts a JWE using an AES-CBC-HMAC content-encryption algorithm (`A128CBC-HS256`, `A192CBC-HS384`, or `A256CBC-HS512`) together with any key-management algorithm that generates a fresh content-encryption key (CEK), the CEK is all zero bytes instead of being randomly generat... |
| <a href="#">CVE-2026-55247</a><br>Newly scored | 9.1  | CRIT |     | 0.003 |                            | plone.app.event provides the event content type for Plone. Prior to versions 5.2.4 and 6.0.1, the iCalendar import in src/plone/app/event/ical/importer.py accepts insufficiently restricted calendar and event URLs, does not adequately bound downloaded bytes or imported events, and commits work per event. A logged-in editor can make the server request internal network resources or local calendar files, exhaust resou... |
| <a href="#">CVE-2026-55248</a><br>Newly scored | 9.1  | CRIT |     | 0.003 |                            | plone.app.portlets provides portlets and a Plone-specific user interface for plone.portlets. Prior to 5.0.8, 6.0.4, and 7.0.2, a member who can add an RSS portlet can set its feed URL to a very large response, causing src/plone/app/portlets/portlets/rss.py to download and retain excessive data in memory and deny service. The same RSS URL handling accepts internal hosts, IP addresses, single-word domains, and expli... |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package  | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-55536</a><br>Newly scored | 9.1  | CRIT |     | 0.003 |                             | PraisonAI is a multi-agent teams system. Prior to praisonai 4.6.58, Browser Server _handle_connection() checks Chrome extension origins with re.match() and the unanchored expression chrome-extension://[a-z0-9]{32}. Extra trailing characters pass before websocket.accept(), allowing start_session commands and unauthorized browser automation. This issue is fixed in version 4.6.58.                                         |
| <a href="#">CVE-2026-55640</a><br>Newly scored | 9.1  | CRIT |     | 0.005 |                             | Nextcloud MCP Server is a production-ready MCP server that connects AI assistants to a Nextcloud instance. Prior to 0.117.2, the POST /webhooks/nextcloud endpoint in nextcloud_mcp_server/vector/webhook_receiver.py has no authentication by default because WEBHOOK_SECRET defaults to None and startup validation does not require it. When WEBHOOK_SECRET is unset, handle_nextcloud_webhook() accepts unauthenticated reque... |
| <a href="#">CVE-2026-57499</a><br>Newly scored | 9.1  | CRIT |     | 0.01  |                             | Liman is open source server management software. Prior to 2.2.2 - 1103, an OS command injection vulnerability in the log rotation configuration endpoint allows an authenticated administrator to execute arbitrary operating system commands on the Liman server. The `ip_address` parameter is embedded directly into a shell command without sanitization, enabling shell escape via single-quote injection. This is fixed in ... |
| <a href="#">CVE-2026-58400</a><br>Newly scored | 9.1  | CRIT |     | 0.012 |                             | GeoNetwork is a catalog application to manage spatially referenced resources. Prior to versions 4.4.12 and 4.2.17, the Saxon XSLT processor used to render formatters is configured without secure processing (`FEATURE_SECURE_PROCESSING`) and without disabling Java extension functions (`ALLOW_EXTERNAL_FUNCTIONS`). Any stylesheet loaded by GeoNetwork can therefore invoke `java.lang.Runtime.exec()` or `java.lang.Proces... |
| <a href="#">CVE-2026-62862</a><br>Newly scored | 9.1  | CRIT |     | 0.005 |                             | Typebot is an open-source chatbot builder. In self-hosted versions up to and including 3.17.1, the default passwordless email magic-link authentication is vulnerable to login-code brute forcing that leads to account takeover. The email provider overrides NextAuth's default cryptographically secure token with a 6-digit code generated using Math.random(), reducing the keyspace to 900,000 with a 10-minute expiry, and... |
| <a href="#">CVE-2026-73253</a><br>Newly scored | 9.1  | CRIT |     | 0.002 |                             | Mongoose is an embedded web server and network library. Prior to version 7.22, an on-path network attacker with a wildcard certificate for a parent domain can impersonate deeper subdomains to a client using the built-in TLS stack. The mg_tls_verify_cert_san() and mg_tls_verify_cert_cn() functions in src/tls_builtin.c call mg_match(), whose wildcard can cross DNS label boundaries, so a pattern such as *.example.com... |
| <a href="#">CVE-2026-73256</a><br>Newly scored | 9.1  | CRIT |     | 0.004 |                             | Mongoose is an embedded web server and network library. Prior to 7.22, a remote unauthenticated attacker can exploit an HTTP/1.0 reverse-proxy deployment by sending a request with Transfer-Encoding: chunked and conflicting framing. The http_cb() function in src/http.c tests hm.proto.len with an impossible greater-than-eight condition even though mg_http_parse() requires an eight-byte protocol string, so is_http_1_... |
| <a href="#">CVE-2026-73257</a><br>Newly scored | 9.1  | CRIT |     | 0.005 |                             | Mongoose is an embedded web server and network library. Priro to version 7.22, a remote unauthenticated attacker can send an HTTP request containing both Content-Length and Transfer-Encoding: chunked. The cl_count and te_count checks in the mg_http_parse() and http_cb() paths in src/http.c accept both headers and prioritize chunked encoding, while a Content-Length-preferring reverse proxy can use a different reque... |
| <a href="#">CVE-2026-75340</a><br>Newly scored | 9.1  | CRIT |     | 0.002 |                             | The device metadata import interface /device/instance/{productId}/property-metadata/import of jetlinks community 2.11 is vulnerable to Server-side request forgery (SSRF).                                                                                                                                                                                                                                                           |
| <a href="#">CVE-2026-77337</a><br>Newly scored | 9.1  | CRIT |     | 0.004 |                             | CakePHP Authentication is an authentication plugin for CakePHP that can also be used in PSR-7 based applications. Versions before 2.11.2, from 3.0.0 through 3.3.6, and from 4.0.0 through 4.2.0 allow authentication bypass and potential CPU or memory exhaustion when CookieAuthenticator uses unencrypted, forgeable legacy tokens. This issue is fixed in versions 2.11.2, 3.3.7, and 4.2.1.                                    |
| <a href="#">CVE-2026-80164</a><br>Newly scored | 9.1  | CRIT |     | 0.002 | dell:secure_connect_gateway | Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to unauthorized access.                                                                                                                               |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-86419</a><br>Newly scored | 9.1  | CRIT |     | 0.002 | misp-project:misp          | Affected versions of MISP contain insufficient validation of server-side outbound HTTP destinations in feed retrieval and TAXII discovery functionality. In feed processing, redirects were followed without validating the redirect scheme or destination. The original request headers were reused across redirect hops, meaning authentication headers or API credentials configured for a feed could be forwarded to a diff...   |
| <a href="#">CVE-2026-87806</a><br>New          | 9.1  | CRIT |     | 0.003 |                            | Parse Server versions <= 8.6.87 and >= 9.0.0 < 9.10.1-alpha.7 contain an authentication bypass in the built-in LDAP authentication adapter. The adapter forwarded the client-supplied password to the directory without verifying that a password had been supplied, and treated any non-error response from the directory as proof of authentication. A zero-length credential turns an LDAP simple bind into the unauthenticate... |
| <a href="#">CVE-2026-67403</a><br>New          | 9.0  | CRIT |     | 0.002 |                            | Cash Collect contains an improper authorization vulnerability in the Sage AR Automation API. Insufficient tenant-level authorization checks allow authenticated users to access administrative resources belonging to other tenants by specifying a valid non predictable tenant identifier.                                                                                                                                         |
| <a href="#">CVE-2026-68484</a><br>New          | 9.0  | CRIT |     | 0.002 |                            | Cash Collect contains an improper authorization vulnerability in the Sage AR Automation API. Administrative functions do not properly verify user privileges, allowing authenticated low-privileged users to create administrator accounts and obtain elevated privileges.                                                                                                                                                           |
| <a href="#">CVE-2026-75604</a><br>Newly scored | 9.0  | CRIT |     | 0.025 |                            | Next.js is a React framework for building full-stack web applications. From 13.4.0 until 15.5.24 and 16.3.3, Next.js applications using Pages Router or App Router without Cache Components on Windows-hosted servers do not consistently escape backslashes in route segments before constructing incremental-cache paths. In packages/next/src/shared/lib/router/utils/escape-path-delimiters.ts and packages/next/src/server/l... |
| <a href="#">CVE-2026-87613</a><br>New          | 9.0  | CRIT |     | 0.004 | google:chrome              | Incorrect reference resolution in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)                                                                                                                                                                                           |
| <a href="#">CVE-2026-87911</a><br>New          | 9.0  | CRIT |     | 0.01  |                            | An OS command injection weakness in the read-only enforcement of the SQL validation component in Amazon awslabs postgres-mcp-server before 1.1.7 might allow an unauthenticated actor to execute operating system commands on the host of a self-managed PostgreSQL server by placing a crafted COPY ... TO PROGRAM statement into content that is processed when an authenticated user interacts with the MCP server in its defa... |

## Watchlist matches (other priorities)

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-19633</a><br>Newly scored | 8.8  | HIGH |     | 0.004 |                            | PostgreSQL Anonymizer contains a vulnerability that allows unprivileged masked users to execute arbitrary code by abusing operators, domain casts, or view subqueries that carry untrusted expressions. When these objects are evaluated in the context of the extension's masking mechanisms, the malicious code can run with elevated privileges. The issue is fixed in PostgreSQL Anonymizer 3.1.4 and later versions             |
| <a href="#">CVE-2026-55509</a><br>Newly scored | 8.8  | HIGH |     | 0.004 |                            | WsgidAV is a generic and extendable WebDAV server based on WSGI. Prior to 4.3.5, the sample MySQLBrowserProvider in wsgidav/samples/mysql_dav_provider.py concatenates the record key parsed from a request URL directly into SQL WHERE clauses. The affected _exists_record_by_primary_key, _get_field_by_primary_key, and _get_record_by_primary_key methods are part of a shipped example provider that is not enabled by defa... |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                           |
|------------------------------------------------|------|------|-----|-------|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-79756</a><br>Newly scored | 8.7  | HIGH |     | 0.051 |                            | Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.17.4, the fix for unauthenticated OS command injection in the nuclio dashboard on the local/Docker platform is incomplete. The fix added validateFunctionName for function names and common.Quote() for the named-resource shell command path, but the list-all resource path (triggered when no specific resource name is provid...  |
| <a href="#">CVE-2026-50553</a><br>Newly scored | 8.6  | HIGH |     | 0.004 |                            | Note Mark is an open-source note-taking application. Prior to version 0.19.5, Note Mark validates book and note slug values with the OpenAPI/huma tag pattern:"[a-z0-9-]+". huma compiles this with regexp.MustCompile(s.Pattern) and tests it with patternRe.MatchString(str), an UNANCHORED match. Because the pattern is not anchored (^...\$), any string that merely CONTAINS one [a-z0-9-] substring passes validation. A sl... |
| <a href="#">CVE-2026-55848</a><br>Newly scored | 8.6  | HIGH |     | 0.003 |                            | mapfish-print is a component of MapFish for printing templated cartographic maps. Prior to 3.28.30, 3.30.32, 3.31.24, 3.33.16, and 4.0.5, MapFish Print accepts an attacker-controlled GML layer url in requests to the /api/print3/print endpoint and fetches XML parsed by core/src/main/java/org/mapfish/print/map/geotools/GmlLayer.java without disabling external entities and external DTDs. A remote XML document and DTD...  |
| <a href="#">CVE-2026-77775</a><br>Newly scored | 8.6  | HIGH |     | 0.004 |                            | Headroom's LLM proxy lets a client choose the upstream destination with the x-headroom-base-url request header. _resolve_openai_upstream_base in headroom/proxy/handlers/openai.py accepts the header value, requires only that it parse with an http or https scheme and a hostname, and returns it for use as the upstream base; _select_passthrough_base_url in headroom/providers/proxy_routes.py reads the same header for t...  |
| <a href="#">CVE-2026-55581</a><br>Newly scored | 8.4  | HIGH |     | 0.003 |                            | mcp-shell is an MCP server for running shell commands securely, auditably, and on demand. Prior to 0.6.0, the default Docker security.yaml includes /bin/bash in allowed_executables, while security.go validates only the first token and checkBlockedPatternsAndCommands does not reject the shell command-mode flag -c. A caller of the shell_exec MCP tool can provide the command argument /bin/bash -c <arbitrary-command>...   |
| <a href="#">CVE-2026-55582</a><br>Newly scored | 8.4  | HIGH |     | 0.002 |                            | mcp-shell is an MCP server for running shell commands securely, auditably, and on demand. Prior to 0.6.0, the default security.yaml allows /usr/bin/git, while security.go omits ! from containsShellMetacharacters and containsDangerousShellConstructs and applies no per-executable argument policy. A caller of the shell_exec MCP tool can provide the command argument /usr/bin/git -c alias.pwn=!<arbitrary-command>, caus...  |
| <a href="#">CVE-2026-86242</a><br>Newly scored | 8.1  | HIGH |     | 0.006 |                            | Bifrost HTTP transport before 2.0.0 accepts an enabled custom plugin whose path is an HTTP URL through unauthenticated POST /api/plugins when management authentication is disabled (the default, governance.auth_config.is_enabled=false). The shared-object loader treats an http-prefixed path as a download URL, writes the body to a temporary .so, and passes it to Go's plugin.Open. After a successful open, optional Ini...  |
| <a href="#">CVE-2026-52831</a><br>Newly scored | 8.0  | HIGH |     | 0.003 |                            | Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.16.4, the Nuclio controller builds a curl invocation string for each cron trigger and stores it as the args of a Kubernetes CronJob container (/bin/sh, -c, <command>). Two fields in the trigger specification flow into this string without adequate sanitization: event.headers keys and event.body. This issue has been patch...  |
| <a href="#">CVE-2026-79755</a><br>Newly scored | 8.0  | HIGH |     | 0.004 |                            | Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.17.4, on the Nuclio local Docker platform, the function namespace is interpolated—unvalidated—into a double-quoted docker ps --filter "label=nuclio.io/namespace=<value>" command that is executed via the host shell (/bin/sh -c). Because the default auth kind is nop (unauthenticated), a remote attacker can inject arbitrar...  |
| <a href="#">CVE-2026-15140</a><br>New          | 7.7  | HIGH |     | 0.002 |                            | A privilege-escalation issue in the Portworx Operator when deployed on Red Hat OpenShift (OCP). Only under specific conditions during the initial provisioning of a Portworx storage cluster, a user holding only limited, namespace-scoped permissions could cause the operator to grant broader access than intended, potentially resulting in elevated privileges within the Kubernetes cluster.                                   |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-54245</a><br>Newly scored | 7.6  | HIGH |     | 0.003 |                            | Fleet is an open-source device management platform built on osquery. In versions prior to 4.86.2, the Okta conditional access integration in Fleet Premium is vulnerable to SQL injection through a host-supplied value that is used in a database query without proper parameterization, allowing an attacker who controls a single enrolled host to read or modify arbitrary data in the Fleet database. The value is reported ... |
| <a href="#">CVE-2026-63404</a><br>Newly scored | 7.3  | HIGH |     | 0.002 |                            | Factory is a language-agnostic background job server. In versions prior to 1.10.0, the embedded Redis bootstrapper is vulnerable to an insecure temporary file flaw that lets a local unprivileged user hijack the Redis configuration and escalate to root. It writes its startup configuration to a fixed, predictable, world-writable path, /tmp/redis.conf, only creating the file if it does not already exist and never val... |
| <a href="#">CVE-2026-79754</a><br>Newly scored | 7.1  | HIGH |     | 0.004 |                            | Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. From version 1.6.19 to before version 1.17.2, Nuclio's Dashboard build pipeline does not sanitize the spec.build.tempDir field before using it to construct a shell command. When the Kaniko container builder is enabled, a user with function-create permission can inject shell metacharacters into this field and achieve arbitrary command exec... |
| <a href="#">CVE-2026-53583</a><br>Newly scored | 6.5  | MEDI |     | 0.002 |                            | libgit2 is a portable C implementation of the Git core methods provided as a linkable library with a solid API, allowing to build Git functionality into your application. Prior to 1.8.6 and 1.9.5, verify_server_cert in src/libgit2/streams/openssl.c uses an inverted !!memcmp result in the GEN_IPADD branch when comparing an IP-literal host with a certificate IP SubjectAltName. OpenSSL builds reject matching IP addre... |
| <a href="#">CVE-2026-19634</a><br>Newly scored | 6.4  | MEDI |     | 0.002 |                            | PostgreSQL Anonymizer contains a SQL injection vulnerability in two import functions. A user can create a malicious JSON document containing specially crafted object names. If a superuser subsequently calls anon.import_database_rules() or anon.import_roles_rules(), the malicious code is executed with superuser privileges. The issue is fixed in PostgreSQL Anonymizer 3.1.4 and later                                      |
| <a href="#">CVE-2026-83534</a><br>Newly scored | 6.4  | MEDI |     | 0.002 |                            | PostgreSQL Anonymizer contains a vulnerability in the anon.anonymize_database_parallel() function that allows the owner of a table to run arbitrary code with superuser privilege. The issue is fixed in PostgreSQL Anonymizer 3.2.0 and later versions                                                                                                                                                                              |
| <a href="#">CVE-2026-32637</a><br>Newly scored | 5.9  | MEDI |     | 0.005 |                            | Velero is an open source tool for backing up, restoring, and migrating Kubernetes cluster resources and persistent volumes. Prior to 1.18.1, an attacker who compromises the backup object-storage backend can upload a malicious backup tarball containing parent-directory paths that escape the extraction directory during restore and overwrite sensitive files in the Velero pod filesystem. This issue is fixed in version... |
| <a href="#">CVE-2026-69129</a><br>Newly scored | 5.8  | MEDI |     | 0.002 |                            | KubePi is a Kubernetes multi-cluster management panel. In versions up to and including 2.0.0, cluster-scoped APIs do not consistently validate per-cluster access, allowing an authenticated user with cluster management permissions to operate on clusters outside the scope they were granted. Because the affected endpoints act on cluster-specific data without confirming that the requesting user is authorized for that ... |
| <a href="#">CVE-2026-85788</a><br>New          | 5.7  | MEDI |     | 0.001 |                            | Incomplete list of disallowed inputs in the mutable SQL detector component in Amazon awslabs mysql-mcp-server might allow context-dependent actors to bypass the read-only enforcement gate and reach file-read and file-write SQL sinks via SQL inline comments that the regex engine does not treat as whitespace. To remediate this issue, users should upgrade to version 1.0.23.                                                |
| <a href="#">CVE-2026-86222</a><br>Newly scored | 5.5  | MEDI |     | 0.003 |                            | A vulnerability has been found in SourceCodester Class and Exam Timetabling System 1.0. This affects the function mysqli_query of the file /admin/modal_add_course2.php. Such manipulation of the argument course leads to sql injection. The attack may be launched remotely. The exploit has been disclosed to the public and may be used.                                                                                         |
| <a href="#">CVE-2026-84371</a><br>Newly scored | 5.4  | MEDI |     | 0.002 |                            | ApostropheCMS is an open-source Node.js content management system, and sanitize-html provides a simple HTML sanitizer with a clear API. From version 1.9.0 until version 2.17.7, packages/sanitize-html/index.js validates an animation value attribute as one flat URL and does not recognize that attributeName selecting href or xlink:href gives the sibling values, from, to, or by attribute SVG SMIL URL semantics. In con... |

| ID                                             | CVSS | Sev  | KEV | EPSS  | Vendor / Product / Package | Description                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------|------|-----|-------|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">CVE-2026-77310</a><br>Newly scored | 5.3  | MEDI |     | 0.002 |                            | jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. Prior to versions 2.18.9, 2.21.5, 2.22.1, 3.1.5, and 3.2.1 on their respective release lines, the java.net.InetAddress branch of FromStringDeserializer.Std._deserialize() calls InetAddress.getByName() on attacker-controlled input, causing eager DNS resolution during deserialization and enabling DNS-b... |
| <a href="#">CVE-2026-84967</a><br>Newly scored | 5.1  | MEDI |     | 0.002 | mongodb:mongodb            | A component of the MongoDB extension for Visual Studio Code does not neutralize special characters in a connection string before that value is placed into a command line the extension composes for an integrated terminal. An unauthenticated remote unauthorized-user who persuades a developer to accept a user-supplied connection target, and then to open the extension's shell feature, can place characters of the unaut... |
| <a href="#">CVE-2026-19729</a><br>New          | 4.9  | MEDI |     | 0.005 |                            | A flaw was found in the key provider component of the keycloak-services library, which is the core engine for the Red Hat Build of Keycloak. The issue occurs because a previous fix for path probing was incomplete, allowing a realm administrator to still submit arbitrary filesystem paths as keystore parameters. This can be used to determine the existence and readability of files on the server, potentially exposing ... |
| <a href="#">CVE-2026-53487</a><br>Newly scored | 4.3  | MEDI |     | 0.002 |                            | Kite is a Kubernetes dashboard. Prior to version 0.12.3, authenticated Kite users with any role can request `/api/v1/overview` for a cluster that their roles do not permit by selecting that cluster with `x-cluster-name`. The overview route is registered before `middleware.RBACMiddleware()` and `GetOverview` only checks `len(user.Roles) > 0`, so it returns aggregate Kubernetes inventory and capacity data from unaut... |

P3/P4 items (1203) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.